FICHE DE SENSIBILISATION À LA CYBERSÉCURITÉ

Comprendre les Failles Zero-Day et N-Day

1. En bref : Qu'est-ce qu'une faille Zero-Day ? (Mots simples)

Imaginez que le fabricant de votre serrure de maison ait commis une erreur de fabrication et créé une faille secrète dans son modèle. Un cambrioleur découvre cette faille avant le fabricant. Il a alors **"0 jour"** pour corriger le problème, car le voleur est déjà capable d'entrer sans clé.

En informatique, une **faille Zero-Day (0-Day)** est une vulnérabilité présente dans un logiciel ou un matériel qui est **inconnue du créateur du logiciel** et pour laquelle **aucun correctif (patch) n'existe encore**. Les cybercriminels peuvent l'exploiter en toute liberté tant que personne ne s'en est rendu compte.

2. Différence entre Zero-Day, N-Day et Vulnérabilités

Pour bien comprendre le cycle de vie des vulnérabilités informatiques, il convient de distinguer ces notions clés :

Notion	Définition	Correctif (Patch)	Niveau de Danger
Vulnérabilité	Faiblesse ou défaut de conception dans un système informatique pouvant être exploité pour porter atteinte à la sécurité.	Variable selon la découverte.	Potentiel
Zero-Day (0-Day)	Faille exploitée par des hackers avant que l'éditeur informatique ne soit au courant ou n'ait le temps de publier un correctif.	**Inexistant (0 jour)**	Très Élevé (Furtif)
N-Day	Faille désormais connue du public et du fabricant, pour laquelle un patch existe depuis N jours, mais qui reste active sur les appareils non mis à jour.	**Disponible**	Élevé (Négligence)

3. Quels sont les risques causés par ces failles ?

- **Vol et fuite de données :** Récupération d'informations confidentielles, bancaires ou personnelles.
- **Prise de contrôle à distance :** Infiltration totale des serveurs ou équipements d'une entreprise.
- **Attaques par Ransonware (Rançongiciel) :** Blocage des systèmes informatiques et demande de rançon.
- **Paralysie des activités physiques :** Interruption d'équipements industriels, médicaux ou de la chaîne du froid.

4. Exemples concrets d'attaques : Zero-Day vs N-Day

Cas Concret Zero-Day : L'attaque Stuxnet (ou le cas Log4Shell)

La situation : En 2010, le ver informatique *Stuxnet* a été utilisé pour cibler et saboter les centrifugeuses de l'usine d'enrichissement d'uranium de Natanz. Les hackers ont utilisé **quatre failles Zero-Day simultanées** dans le système d'exploitation Windows.

Pourquoi c'était du Zero-Day : Ni Microsoft ni les ingénieurs de l'usine ne connaissaient l'existence de ces failles. Les attaquants ont pu s'infiltrer et prendre le contrôle des installations industrielles en toute discrétion pendant des mois, car **aucun correctif n'existait** au moment de l'attaque pour bloquer l'intrusion.

Cas Concret N-Day : Le piratage des réseaux de froid en France

La situation : En France, des hackers ont ciblé des systèmes intelligents de gestion de température connectés à des frigos et congélateurs commerciaux dans des magasins et supermarchés.

Pourquoi c'était du N-Day : Le fabricant avait déjà découvert la faille et **publié un patch de sécurité** plusieurs semaines avant l'attaque. Cependant, certains commerçants n'avaient pas installé la mise à jour sur leurs équipements.

L'impact : Les pirates ont scanné Internet à la recherche des frigos non mis à jour et ont modifié les températures à distance, provoquant la rupture de la chaîne du froid et la perte totale des stocks alimentaires.